Source: docs\ENQUIRIES.md | Export: 11 November 2026

Contact form and Customer Enquiries

Flow and source

`/contact` now has an anonymous form and the existing saved Contact Information components. Desktop shows the contact registry beside the form; mobile places the form first. The customer header, footer and five-tab mobile navigation remain unchanged. Lora, maroon/ivory/gold and the existing compact admin shell remain unchanged. `/admin/enquiries` replaces its placeholder; Customer Enquiries was already positioned before Settings in the shared navigation and keeps that position.

`ContactForm` posts JSON to the existing `/api/catalog` function using the exact public action `enquiries:submit`. No account or token is required. Every other POST action still requires the existing bearer authentication, and all enquiry administration additionally requires both `admin:true` and enabled `adminAccess/{uid}`. The handler decodes buffered UTF-8 bytes once, preserving Unicode split across transport chunks, and retains bounded JSON parsing and limits the public enquiry payload to 16,000 bytes. There is no new serverless function, rewrite or API package.

Submission accepts only `action`, `enquiry`, `operationId` and the empty honeypot `website`. The enquiry accepts only name (160), email (254), optional phone (50), valid ISO phone country and message (2,000 characters). Client/server validation share the same model. Names/email reject controls, phone uses the existing `libphonenumber-js/max` normalization, and message preserves Unicode and normalized paragraph breaks. New empty country controls default to IN/+91; absolute pasted international numbers infer their own country. Phone is optional and is not treated as a WhatsApp number.

The server creates `enquiries/{operationId}` with `schemaVersion:1`, validated name/email/normalized phone/message, derived `searchPrefixes`, initial `status:New`, trusted `createdAt`/`updatedAt`, and `revision:1`. No visitor-supplied UID, status, timestamp, owner or internal metadata is accepted. Signed-in submitters also use the same general form; account identity is not asserted or linked automatically. No customer profile, Auth account, marketing subscription, order, business contact, notification or outgoing message is created.

Only `{received:true}` is returned. The UI clears the form only after this confirmed receipt and displays a persistent inline “Your message has been received.” panel with truthful follow-up guidance and Send Another Message. See `ABOUT_CONTACT_STOREFRONT_DESIGN.md`. Unknown responses retain inputs and the same operation ID for safe retry. Duplicate clicks are locked; changing to a different normalized submission generates a new operation. No response deadline or notification promise is shown.

Abuse bounds and retries

The existing transaction-backed limit pattern is adapted for anonymous submissions. `enquirySubmissionLimits` enforces at most 5 accepted messages per normalized email per UTC hour and 200 globally per UTC hour, atomically with the new enquiry. Email bucket IDs contain SHA-256 digests, not raw addresses. The global bound limits rotating-address submissions as well. The empty honeypot and server field/size validation reject malformed submissions. Browser cross-origin JSON requests receive no CORS grant. No IP fingerprinting or new CAPTCHA credential is required.

Excess submissions receive HTTP429, `Retry-After:3600` and clear temporary-limit feedback. A previously accepted exact retry succeeds without consuming another allowance, including when the current allowance is exhausted. Counters carry an `expiresAt` housekeeping timestamp, but this change does not install a TTL policy or automatic cleanup.

`enquiryReceipts/{operationId}` stores a payload digest and trusted receipt timestamp. It contains no name/email/phone/message. Conflicting reuse of an operation is rejected. This minimal private receipt remains after deletion to prevent a late uncertain submission retry from recreating a deleted enquiry. Delete retry metadata also contains no customer message or contact details. Raw bodies, messages and contacts are not logged by this flow; existing safe diagnostic serialization remains in use.

Administration

`enquiries:list` applies database-wide, case-insensitive NFKC prefix search by full name, name-word, email, international phone digits or national phone digits. It is explicitly labelled prefix search, not substring/full-text search or a search limited to loaded rows. Filters All/New/Read/Replied combine with search. Queries order `createdAt DESC`, then document ID DESC and return 20 rows plus an opaque cursor. Cursors contain filter signatures and exact timestamp seconds/nanoseconds/ID; reusing a cursor for different filters is rejected. Load More retains the list and scroll position. No invented total or New count is shown; loaded counts identify their scope. Refresh is explicit, with distinct loading, failure/Retry, empty and no-match states. The page does not claim to be a live feed.

`enquiries:get` returns only the submitted fields, status, real reference, timestamp and revision. Original fields are read-only. Details uses a native desktop drawer/mobile full-screen dialog with focus containment/restoration, Escape, scroll locking, wrapped plain-text messages and a scrollable body above fixed actions. Opening it does not mutate status. The list remains mounted, preserving filters/search/position. Requests are aborted and late responses discarded on filter changes, detail changes, navigation and sign-out; no private enquiry state is written to browser storage.

New means awaiting review; Read means reviewed; Replied means an administrator confirms follow-up. Explicit actions permit New→Read, New→Replied and Read→Replied. Replied cannot silently revert to Read. `enquiries:update` requires revision and operation ID and rechecks enabled access in its transaction. Successful updates appear only after server confirmation and update/remove the affected list row according to the current status filter. Stale/deleted records produce recoverable reload feedback.

Email opens an encoded `mailto:` link; optional phone opens normalized `tel:`. Copy Email is explicit and handles clipboard failure. No action sends a message automatically or changes status. WhatsApp is intentionally omitted for visitor numbers because the form establishes no WhatsApp capability. Missing phone displays “Phone not provided” with no broken call action.

`enquiries:delete` requires a selected ID, current revision and operation ID, rechecks administrator access, and permanently deletes only that enquiry. Confirmation uses “Delete this enquiry?” / “This enquiry and its message will be permanently removed.” / Cancel / Delete Enquiry. A confirmed delete retry is idempotent; stale/conflicting mutations are rejected. Only private non-content receipt/delete metadata remains. No bulk deletion exists.

Screenshot-only Add Enquiry, Compose Dispatch, export, selection checkboxes, inferred tags/weave metadata, certifications, invented people/counts, fake service guarantees and chat/composer features are omitted. Actual source-driven contact components are reused rather than duplicating the business contact configuration. No Loyalty Points changes are included.

Exact release dependencies

Application code must be released by the owner. Three **new, local-only** composite definitions are appended to `firestore.indexes.json`; preserve all existing definitions. Target `parinaya-silks` / `(default)`, collection group `enquiries`, query scope **COLLECTION**:

Query	Ordered fields
Status-filtered, newest-first	`status ASCENDING`, `createdAt DESCENDING`
Prefix search, newest-first	`searchPrefixes CONTAINS`, `createdAt DESCENDING`
Prefix search + status	`searchPrefixes CONTAINS`, `status ASCENDING`, `createdAt DESCENDING`

The repository convention omits the implicit trailing `__name__ DESCENDING`, which matches the explicit document-ID ordering in these queries. Unfiltered newest-first uses the normal single-field index. The owner must create only missing exact definitions and verify READY before hosted filtered/search acceptance. Emulator success does not prove index readiness.

No new Firebase rule change is necessary: the existing local rules deny direct access to these undeclared collections, including direct administrator SDK reads; all administration is through the trusted API. The release must retain deployed rules equivalent to that existing deny policy. Deployed rule/index state was not inspected or changed during this local task. No source migration, environment variable, mail/WhatsApp provider or additional hosting function is required.

Verification

`src/enquiries/model.test.tsx` covers required/optional validation, Unicode/paragraphs, safe text, normalized contact links and search prefixes. `scripts/enquiries-emulator.test.ts` exercises the exported HTTP handler, anonymous receipts, both admin checks, direct-read/write denial, duplicate/uncertain retry, actual429 limits, search/filter/newest-first pagination, cursor mismatch, transitions, concurrent mutations, deletion/replay protection and unrelated-record preservation. Existing Contact Information emulator/browser regressions also run.

`scripts/enquiries-browser.test.py` exercises the real loopback contact→private list→details→follow-up→delete flow, uncertain submit/delete replies, field/rate feedback, explicit statuses, stale revision recovery, missing phone, safe links without opening external apps, literal script/Unicode content, preserved inputs/search, dialog Escape/focus behavior and widths 320-1920. All mutations and source data are synthetic emulator fixtures. Typecheck, unit tests, production build and packaged Vercel API runtime checks are local evidence only. Hosted acceptance with existing authorized sessions remains outstanding; no live enquiry or outgoing message was created.

Local completion: typecheck, 126 unit tests, production build, packaged API runtime probes, enquiry/Contact Information emulator suites and enquiry/Contact Information browser suites passed. The complete unrelated admin harness was not rerun. The handler regression explicitly covers split UTF-8 and oversized anonymous requests.